

Exercise 04: Social Engineering

4.a Defence

4.a.1 Which technical tools can be used to defend against social engineering attacks and against which?

To defend against social engineering attacks, several technical tools can be used, including:

1. Phishing, an attempt to induce the victim to provide personal information. Some tools can be useful to avoid **Phishing Attacks**, such as **Email Authentication Protocols** (like SPF, DKIM and DMARC), **Mail Filters** or **External Email Banners**. The most widely used are the Email Authentication Protocols: they validate the sender's domain identity, preventing attackers from spoofing trusted email addresses.
2. Scareware, using fear and fake security alerts to trick the victim into purchasing useless software, downloading malware, or over-sharing personal information. Possible security measures could be **Pop-Up Blockers**, **Advertising Blockers**, **URL Filters** (recognizing fraudulent websites) or **DNS Filters**.
3. Watering hole, which compromises a trusted website to deliver malware. The safety measures are **Secure Web Gateway** and/or **Web Application Firewalls**. Web Application Firewalls protect the target website's server from being exploited by the attackers in the first place, while Secure Web Gateways serve as intermediate inspection point between the end user and the attacker, blocking malicious scripts provided by a compromised web site.
4. Spear Phishing, uses the same technology as phishing but in a targeted way. After learning victim's personal information (by obtaining details through passive scanning), the attacker could create fake emails and websites specifically for that victim. The same tools used for Phishing could be used for this specific type of threat. However, Spear Phishing emails can easily bypass basic spam filters by using personalized and not-spam text; for this main reason, additional tools as **AI-Based Email Anomaly Detection** and **External Email Banners** are very useful to recognize this kind of Social Engineering Attack.

4.a.2 Give examples on how you, as IT-experts, can either stop or mitigate Social Engineering.

On one hand, as IT-expert, you would stop Social Engineering Attacks by building technical walls between the victim and the attacker, intercepting Attack Vectors before a human interacts with them.

Enforcing Domain Authentication

Domain Authentication is the collection of technical proofs that a message, an email or a service response actually comes from the domain it claims.

- **Example:** all the incoming emails must be signed and policy-checked so the receiver can distinguish legitimate communications from phishing sent through similar infrastructures.

Secure Email Gateway

A Secure Email Gateway is an email security product that blocks malicious emails before they reach recipients, some of them are SPF, DKIM and DMARC protocols.

- **Example:** if an attacker registers a domain similar to the main used services available (like micros0ft.com), the Secure Email Gateway automatically flags the email before it reaches the receiver's inbox.

Multi-Factor Authentication

MFA (Multi-Factor Authentication) is a tool used to verify identities by requiring at least two distinct proofs, like a password, biometric data like face ID or fingerprint, or external authenticator services (such as Microsoft Authenticator).

- **Example:** an attacker could trace the password of some company employee but, thanks to Multi-Factor Authentication, could not access the final system because they can't provide other proofs required by security systems.

On the other hand, if a user has been psychologically manipulated, IT-experts should use architectural infrastructures to contain their final impact.

Principle of Least Privilege

The principle of Least Privilege is a security concept in which users receive only the minimum access rights they need to do a task.

- **Example:** if a user has been manipulated into downloading malicious software or providing their credentials, the attacker cannot access information beyond the scope of that specific user.

Phishing Reporting

Phishing Reporting could be a client-side UI extension integrated directly into the organization's email software that enables employees to report likely phishing attacks.

- **Example:** if an employee accidentally clicks on a malicious link, providing the attacker their credentials, and reports it, the Security Operation Center (SOC) team is immediately notified, automatically deleting the same email from all the other employees' inboxes.

4.b Experiment: Attack & Defence

4.b.1 The Social Engineers will

- tailor an attack based on the information on our fictive victim DAN (see slides), based on the lecture materials. For the submission: describe the steps and tools used for your attack, why do you structure your attack the way you do and how do you incorporate your knowledge on DAN? Discuss your choices. Two (not too long) paragraphs should suffice.

The Attack

This attack will consist on a simple spear-phishing campaign which we'll orchestrate making use of the OSS framework GoPhish. This way, we'll craft an email that looks like it came from DAN's corporate environment, which presents itself as an HR routinely administrative request such as asking him to choose his next shift because of a schedule mismatch. Our victim will then be directed through a fake link, since you can

camouflage them making them display something different than what they point to a fake portal (that we generated using GoPhish as well) where our trap lies. This webpage has been generated using the real one as a template and will prompt him to log in. If the official one happens to rely on a Single-Factor Authentication (a password and that's it) we don't have to worry about further obfuscation. Otherwise, if their auth system accounts for MFA, we will have to simulate it by some traffic routing (this can be implemented with another tool such as Evilginx).

Linking it to our Victim

Rather than employing social engineering strategies such as an aggressive iteration of scareware containing flashy clickbait or fabricated urgency, we have adapted our approach to our victim's collected profiling. An email might just be the perfect option for this kind of person, as a phone call (vishing) would likely put a loner like him on the spot. Additionally, he's more than likely to respond positively to a formal request given his high conscientiousness (which guarantees traits like rule-abiding, for instance) and not so likely to dig into the web's source code to inspect its veracity due to his trusting nature and low curiousness.

4.b.2 The Defenders will

- tailor a course to DAN, to make sure that he is aware of and protected in the best possible way against social engineering attacks. Optionally, you can think about a nice concept on how to do this, but this is not the essential part. For the submission: provide an outline of your course, describing why you picked the specific snippets. How do you think you can provide general awareness, awaken a sense of urgency for the topic in DAN? How would you make the course practical? Discuss your choices. Two (not too long) paragraphs should suffice, too.

The Course

To effectively safeguard DAN against Social Engineering, we could design a security course introducing some topics related to the main types of attacks. However, the security course should not clash with DAN's routine, respecting his psychological profile. The course begins with a snippet on **Link & Domain Verification**, training him to inspect hyperlink destinations and spot fake domains before clicking on them. We then cover **Authentication Awareness**, explaining how modern phishing techniques bypass Single-Factor and Multi-Factor Authentication processes, including why providing credentials into malicious websites could have a huge impact on the corporate environment. Finally the last snippet would be about **Verification Protocols** for incoming administrative and organizational communications, introducing standard procedures for validating urgent requests. Rather than passive video lectures, the course is made practical through sandbox exercises, allowing DAN to practice over simulations and become familiar with all the listed topics.

Awakening his sense of urgency

By examining DAN's psychological profile, we should consider some aspects in order to provide him with a sense of urgency and awareness on the subject. To effectively engage DAN, we could highlight his **high conscientiousness** by presenting cybersecurity as a core aspect of the enterprise, not just an optional topic. Awakening a sense of urgency for a conscientious employee does not require scare strategies; instead, we describe data illustrating the impact of Social Engineering on company and colleagues. Furthermore, given DAN's **introverted behaviour**, we deliver the course through online modules rather than a large group-work or live meetings. This allows us to awaken his responsibility while respecting his psychological profile.

4.b.3 Afterwards, regroup to have small groups with both, Social Engineers and Defenders.

- Present your approaches and then discuss if your strategies are matched or if you could strengthen the defence or harden the attack. For the submission: †compare the chosen attack to your course content, assuming that you have been working on attacking/training the same subjects. Discuss how the defending/attacking side needs to improve, can adjust to the situation, the attack they face. Again, try get along with one paragraph for each aspect.

Attacker Perspective

Our spear-phishing chain (GoPhish campaign + cloned login portal, Evilginx for adversary-in-the-middle to defeat MFA) maps directly onto the course's phishing/spear-phishing block and the defensive tools we studied, but it stops short of the recon and post-exploitation skills also taught. To improve it, the attacking side should first run the same passive footprinting practised in the whois/dig/nmap exercises against DAN's employer — SPF/DKIM/DMARC and MX records, exposed portals, leaked metadata — to choose a spoofing strategy that survives email authentication and to enrich the pretext with verifiable detail. It must also adapt when defences appear: use look-alike domains with valid TLS and redirect chains if the clone is flagged, and fall back to another course vector (watering hole, scareware or vishing) when MFA is phishing-resistant. Finally, chaining the stolen credentials/session into post-exploitation with the Metasploit/meterpreter tooling, while applying the nmap spoofing options for attribution control, turns a credential phish into real persistence.

Defence Perspective

While the security course covers general topics such as link inspection and authentication awareness, relying only on human awareness may not be enough against more sophisticated spear-phishing attacks. To improve defence, we should provide a deeper dive into spear-phishing techniques, raising DAN's knowledge about advanced attacking strategies like fake internal requests. This emphasis on showing more about this topic to DAN also makes sense because phishing is one the most common attacks. By the way, at the same time we need some technical solution from security systems, and one of those could be a phishing reporting tool: a client-side UI extension directly integrated in the email software that enables DAN to report suspicious organizational requests.

4.c The assessment treated Metasploitable 3 as a static target. Real attackers and real organisations change. Reflect on one development that would defeat your current attack or your current course, for example AI-generated phishing, voice deepfakes or impersonation of the internal IT team. Where does responsibility for withstanding social engineering lie when it can bypass every technical control: with the individual (DAN), the organisation (culture, hierarchy, policies), or the security professional who wrote the assessment? Use at least one model from the lecture (Cialdini, Hofstede/Schein, Big Five) to support your argument, and state what a follow-up assessment should include so that it covers the human layer as well. [max two short paragraphs.]

A good example of an social engineering attack that is very likely to completely bypass both human intuition and defence protocols is the combination of AI-Gen and deepfake techniques for voice and facial impersonation. In this case, the attack relies on trust making the technical controls irrelevant. Cialdini's Principles of Influence (in particular the Authority Principle) explain why DAN complies with someone who

looks like his manager or comes from the HR department or the IT Team, and why he assumes others would do the same. Hence, in this case, the responsibility should befall on the organization rather than the individual. Schein's Model of Organizational Culture places human assumptions at the base of the pyramid, and so it's unrealistic to expect rigorous verification by the individual. What isn't unrealistic, though, would be to enforce policies that relieve pressure from the human layer. There could be process controls on financial requests, or other relevant actions that require security measures, that trigger the need for access tokens on both ends (something similar to a cryptographic handshake).